

CISSP Printable Practice Exam 03 - Domain 3 - Security Architecture and Engineering

Domain 3

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-040)

Scenario: A research organization is designing a laboratory records system. Authorization decisions depend on a separate policy service, and the records are highly confidential.

If the policy service becomes unavailable, which system behavior BEST implements the fail-secure principle?

- A. Permit all authenticated users until the policy service recovers.
- B. Retain each user's most permissive authorization from the prior session.
- C. Deny new access requests while preserving only explicitly approved emergency procedures.
- D. Disable audit logging to reduce demand on the remaining services.

Question 2 (CISSP1-041)

Scenario: A government contractor must prevent analysts from reading information above their clearance and from writing classified information into a lower classification level.

Which formal security model MOST directly supports these requirements?

- A. Bell-LaPadula
- B. Biba
- C. Clark-Wilson
- D. Brewer-Nash

Question 3 (CISSP1-042)

Scenario: A financial services firm found that one infrastructure administrator can request, approve, and implement changes to the hardware root of trust used by critical servers.

Which redesign BEST applies separation of duties while retaining operational accountability?

- A. Rotate the administrator's password after each approved change.
- B. Require an independent approver and separate implementation role, with attributable audit records.
- C. Allow the administrator to proceed after documenting the business reason in a personal log.
- D. Grant the same end-to-end privileges to a backup administrator for availability.

Question 4 (CISSP1-043)

Scenario: An online payment service needs centralized generation, storage, and use of private signing keys. The keys must remain nonexportable, and cryptographic operations require strict administrative controls.

Which security capability is the MOST appropriate foundation for this requirement?

- A. A hardware security module with controlled key operations
- B. A trusted platform module installed in each employee workstation
- C. Encrypted application configuration files stored with the servers
- D. Process isolation within the payment application's operating system

Question 5 (CISSP1-044)

Scenario: A media company is redesigning an internal application environment after learning that network location is treated as sufficient evidence of trust.

Which TWO design changes BEST align with zero trust principles? Select 2 of the 5 options below.

- A. Authorize each request using current identity, device, and resource context.
- B. Place all internal applications on one trusted network segment.
- C. Grant broad access after a user successfully connects to the corporate network.
- D. Continuously evaluate access signals and restrict privileges to required resources.
- E. Replace application authorization with perimeter firewall rules.

Question 6 (CISSP1-045)

Scenario: A water treatment facility operates legacy controllers that cannot support endpoint agents or frequent patching. A recent review found direct routable connectivity between office workstations and the control environment.

Which architectural change should the security architect recommend FIRST?

- A. Replace every controller immediately with a general-purpose server.
- B. Segment the control environment and tightly mediate required communications through monitored boundaries.
- C. Install the corporate endpoint agent on every controller despite compatibility concerns.
- D. Increase password complexity on office workstations without changing connectivity.

Question 7 (CISSP1-046)

Scenario: A development platform will execute untrusted customer workloads in containers. The security team is concerned that a container escape could expose other tenants because containers share the host kernel.

Which design MOST effectively addresses the stated risk?

- A. Run every container with privileged mode enabled for compatibility.
- B. Use hardened minimal hosts, unprivileged containers, mandatory isolation controls, and stronger workload boundaries where required.
- C. Scan approved container images before deployment but leave runtime privileges and host settings unchanged.
- D. Assign separate application credentials to each tenant while retaining the shared default kernel configuration.

Question 8 (CISSP1-047)

Scenario: A retailer deploys an application on a managed platform service. The provider maintains the physical infrastructure, virtualization layer, operating system, and platform runtime.

Which responsibility MOST clearly remains with the retailer?

- A. Replacing failed disks in the provider's data center
- B. Patching the provider-managed hypervisor
- C. Securing application code, identities, configuration, and customer data
- D. Maintaining the provider's physical perimeter controls

Question 9 (CISSP1-048)

Scenario: A hospital uses network-connected environmental sensors with fixed firmware and hard-coded service credentials. Replacement is scheduled but will take nine months, and the devices need to send readings only to one collection service.

What is the BEST interim architectural mitigation?

- A. Place the sensors on a restricted segment that permits only necessary traffic to the collection service and monitors anomalies.
- B. Require administrators to use a managed workstation while leaving the sensors on the general user network.
- C. Place the sensors behind a gateway that authenticates administrators but permits unrestricted outbound sensor traffic.
- D. Increase monitoring of the existing flat network without restricting communication paths.

Question 10 (CISSP1-049)

Scenario: A benefits portal currently allows desktop clients to connect directly to a database using one shared account with broad table permissions.

Which redesign BEST reduces the architectural vulnerability?

- A. Hide the shared database password in the desktop application's compiled code.
- B. Route requests through a service layer that validates authorization and uses narrowly scoped database privileges.
- C. Rename sensitive tables so users cannot easily identify them.
- D. Give each desktop client the shared account through an encrypted configuration file.

Question 11 (CISSP1-050)

Scenario: A procurement system sends approved purchase orders to external suppliers. Suppliers must be able to verify that an order was not altered and that it was approved using the organization's controlled private key.

Which mechanism BEST satisfies both requirements?

- A. A digital signature over the purchase order
- B. A plain cryptographic hash sent with the purchase order
- C. Symmetric encryption using one shared key for every supplier
- D. A random salt appended to the purchase order

Question 12 (CISSP1-051)

Scenario: A manufacturer is defining a lifecycle for keys that protect proprietary design archives. The current process permits administrators to generate keys on ordinary workstations and retains retired key copies indefinitely without documented need.

Which TWO controls would MOST directly improve the cryptographic key lifecycle? Select 2 of the 5 options below.

- A. Generate keys using an approved source of cryptographically secure randomness in a controlled environment.
- B. Publish private keys with the archive so future users can recover the data.
- C. Define retention, archival, revocation, and destruction rules based on data and recovery requirements.
- D. Reuse one key across unrelated systems to reduce administrative effort.
- E. Extend every key's cryptoperiod whenever rotation creates operational work.

Question 13 (CISSP1-052)

What is the PRIMARY security benefit of applying a unique random salt to each password before using an appropriate password-hashing function?

- A. It makes identical passwords produce different stored values and reduces the usefulness of precomputed tables.
- B. It makes weak passwords resistant to every offline guessing attempt.

- C. It allows the server to recover the original password when needed.
- D. It provides non-repudiation for each successful login.

Question 14 (CISSP1-053)

Scenario: An enterprise discovers credible evidence that the private signing key of an internal intermediate certificate authority was extracted by an attacker.

Which response BEST protects relying systems from certificates fraudulently issued under the compromised key?

- A. Increase the key length of newly issued end-entity certificates while retaining the intermediate authority.
- B. Revoke the compromised intermediate certificate, distribute updated trust and revocation information, and reissue affected certificates under a new protected key.
- C. Wait until the intermediate certificate expires to avoid disrupting applications.
- D. Change the certificate authority's display name and continue using the existing signing key.

Question 15 (CISSP1-054)

Scenario: A laboratory demonstrates that private-key bits can be inferred by correlating thousands of cryptographic operations with small variations in device power consumption.

What type of attack does this finding MOST directly demonstrate?

- A. Ciphertext-only attack
- B. Frequency-analysis attack
- C. Side-channel attack
- D. Known-plaintext attack

Question 16 (CISSP1-055)

Scenario: A data center is redesigning fire protection for an equipment room that technicians routinely occupy. Management wants early warning and suppression that minimizes harm to people and electronic systems.

Which design is MOST appropriate?

- A. Smoke detection combined with a code-compliant pre-action system and an appropriate clean-agent system where justified by risk
- B. A total-flooding carbon dioxide system with alarms but no engineered mechanism to prevent discharge while personnel remain inside
- C. A conventional wet-pipe sprinkler system selected solely for low installation cost, without evaluating accidental-discharge exposure
- D. Heat detection paired with portable extinguishers as the only suppression capability for the entire equipment room

Question 17 (CISSP1-056)

Scenario: A regional utility is building a control room inside an existing operations facility. Tailgating and misuse of valid badges are the primary concerns.

Which control design BEST addresses both concerns?

- A. A standard keyed lock with a sign reminding employees not to share keys
- B. An access-controlled vestibule using badge and biometric verification, anti-passback logic, monitoring, and retained access logs
- C. A reception desk located at the public entrance with no controls at the control room
- D. A shared numeric code changed annually and distributed to all facility personnel

Question 18 (CISSP1-057)

Scenario: An organization is comparing locations for a new processing facility that must support critical services during regional disruptions.

Which TWO factors should receive the GREATEST attention during site selection? Select 2 of the 5 options below.

- A. Exposure to hazards such as flooding, wildfire, severe weather, and nearby hazardous operations
- B. Availability and independence of power, communications, water, and emergency access routes
- C. The site's proximity to the largest current group of office employees
- D. The cost of adapting existing interior office space for administrative teams
- E. The ability to standardize interior lock hardware with noncritical corporate offices

Question 19 (CISSP1-058)

Scenario: A project will deploy high-density computing equipment in a converted office area. The system design is nearly complete, but no one has assessed power, cooling, floor loading, fire protection, or physical access zoning.

What should the security architect recommend as the BEST next step?

- A. Complete procurement first and address facility limitations after installation.
- B. Perform a multidisciplinary facility risk and capacity assessment before final design approval.
- C. Treat the equipment vendor's warranty as acceptance of all environmental risks.
- D. Limit the review to cybersecurity configuration because the equipment is already selected.

Question 20 (CISSP1-059)

Scenario: A company is closing a branch data room. Servers will be reused, storage media will be disposed of, and the leased space will be returned to the property owner.

Which decommissioning approach BEST protects information and the former facility?

- A. Move reusable servers first and let the property owner discard remaining media and access badges.
- B. Inventory assets, apply approved media sanitization or destruction, revoke physical and logical access, remove sensitive markings, and retain evidence of completion.
- C. Delete visible files from storage media and leave installed access-control devices unchanged.
- D. Rely on the lease termination date to end all personnel and system access automatically.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-040) - Correct: C

Denying new requests places the system in a secure state when it cannot obtain an authorization decision, while a separately approved emergency procedure can address availability needs. Permitting access or retaining the most permissive prior state could expose confidential records. Disabling logging weakens accountability and does not solve the authorization failure.

Question 2 (CISSP1-041) - Correct: A

Bell-LaPadula is designed to protect confidentiality through rules commonly summarized as no read up and no write down. Biba focuses on integrity, Clark-Wilson emphasizes well-formed transactions and separation of duties, and Brewer-Nash addresses conflicts of interest through dynamic access restrictions.

Question 3 (CISSP1-042) - Correct: B

Splitting approval and implementation between accountable individuals prevents one person from completing the entire sensitive transaction and creates traceable oversight. Password rotation does not separate authority. A personal log is not independent approval, and duplicating the same end-to-end privilege preserves the original control weakness.

Question 4 (CISSP1-043) - Correct: A

A hardware security module is designed to generate, protect, and use high-value keys inside a tamper-resistant boundary with controlled administration. A trusted platform module primarily supports the integrity and key needs of its host device. Encrypted configuration files still expose keys to host processes, while process isolation alone does not provide equivalent key custody.

Question 5 (CISSP1-044) - Correct: A, D

Context-aware authorization for each request and continuous evaluation with least privilege directly reduce implicit trust. A single trusted segment and broad post-connection access preserve location-based trust. Perimeter rules remain useful controls but cannot replace resource-level authorization in a zero trust design.

Question 6 (CISSP1-045) - Correct: B

Segmentation with controlled, monitored communication paths reduces exposure without disrupting fragile controllers and is a strong first architectural control. Immediate wholesale replacement may create safety and availability risk. Unsupported agents can impair operations, while office password changes do not address the direct network path into the control environment.

Question 7 (CISSP1-046) - Correct: B

Hardened hosts, reduced container privilege, enforced isolation, and stronger boundaries for higher-risk workloads provide defense in depth against shared-kernel compromise. Privileged containers increase exposure, a shared writable registry creates supply-chain risk, and application passwords do not isolate kernel resources.

Question 8 (CISSP1-047) - Correct: C

In a managed platform model, the customer remains responsible for its application, identities, configurations, and data even when the provider operates lower layers. Physical facilities, disks, and the provider-managed hypervisor are provider responsibilities. Exact allocations should still be confirmed in the service agreement.

Question 9 (CISSP1-048) - Correct: A

A restricted segment with allowlisted communication and monitoring limits both the reach and impact of devices that cannot be secured internally. A managed administrative endpoint improves one access path but leaves the devices broadly exposed. Gateway authentication without outbound restriction and monitoring without segmentation each address only part of the risk.

Question 10 (CISSP1-049) - Correct: B

A controlled service layer can enforce business authorization and limit database operations through narrowly scoped identities. Credentials embedded in code or configuration can still be extracted and retain excessive authority. Renaming tables provides obscurity rather than access control.

Question 11 (CISSP1-050) - Correct: A

A digital signature lets a recipient verify document integrity and validate that the corresponding private key produced the signature. A plain hash detects changes only when its trusted value is delivered separately and does not authenticate the signer. Shared symmetric encryption does not provide the same third-party-verifiable origin assurance, and a salt alone supplies neither property.

Question 12 (CISSP1-051) - Correct: A, C

Secure generation protects keys at creation, while defined archival, revocation, retention, and destruction rules control them through retirement. Publishing private keys destroys confidentiality. Broad reuse increases the effect of compromise, and repeatedly extending cryptoperiods for convenience ignores risk-based lifecycle requirements.

Question 13 (CISSP1-052) - Correct: A

A unique salt causes equal passwords to produce different stored verifiers and forces attackers to perform work separately for each salt instead of efficiently reusing precomputed results. Salting does not make weak passwords unguessable, enable password recovery, or create a digital signature that could support non-repudiation.

Question 14 (CISSP1-053) - Correct: B

Revoking the compromised authority and propagating that status removes trust from certificates chained through it; controlled reissuance under a new protected key restores service. Stronger end-entity keys cannot repair a compromised issuer. Waiting leaves fraudulent certificates trusted, and renaming the authority has no cryptographic effect.

Question 15 (CISSP1-054) - Correct: C

Power analysis is a side-channel attack because it exploits physical information leaked by an implementation rather than a mathematical weakness in the algorithm. Ciphertext-only and known-plaintext attacks are categorized by the attacker's available cryptographic data. Frequency analysis studies symbol patterns and is not the mechanism described.

Question 16 (CISSP1-055) - Correct: A

Early smoke detection plus a properly engineered pre-action system reduces accidental water release, while an appropriate clean agent can protect equipment when risk justifies it; all elements must meet life-safety and code requirements. Carbon dioxide presents a serious life-safety concern in occupied areas. A wet-pipe system chosen without risk analysis may create avoidable exposure, while heat detection and portable extinguishers alone provide insufficient early and automatic protection.

Question 17 (CISSP1-056) - Correct: B

A controlled vestibule limits passage to one verified person, while badge-plus-biometric checks reduce misuse of a badge and monitoring and logs provide detection and accountability. A key or shared code can be copied or shared. A distant reception desk does not adequately control the critical room itself.

Question 18 (CISSP1-057) - Correct: A, B

Regional and adjacent hazards shape the facility's inherent exposure, while resilient utilities and access determine whether critical services can continue through disruptions. Employee proximity and adaptation cost may affect business planning but do not address the stated resilience objective as directly. Standard lock hardware is secondary to selecting a site with acceptable hazard and infrastructure characteristics.

Question 19 (CISSP1-058) - Correct: B

A multidisciplinary assessment before design approval can identify safety, availability, and physical security requirements while changes remain feasible. Procurement would prematurely lock in assumptions. A warranty does not transfer all operational risk, and a cybersecurity-only review ignores dependencies that directly affect system reliability and protection.

Question 20 (CISSP1-059) - Correct: B

A controlled decommissioning process maintains asset accountability, protects residual data, removes obsolete access, and documents completion. Delegating media disposal without control can expose information. Ordinary deletion may leave recoverable data, and lease termination does not automatically revoke credentials or remove sensitive facility artifacts.